

Guida alla messa in produzione

Setup completo: hosting, variabili d'ambiente, Stripe, backup e go-live checklist

astro-directus-ecommerce · github.com/simone-bernazzi/astro-directus-ecommerce · Maggio 2026

FASE 1

Directus CMS

Hosting cPanel/VPS, database MySQL, token API, schema collezioni

FASE 2

Stripe

Account, chiavi API, webhook endpoint, test pagamenti

FASE 3

reCAPTCHA

Registrazione sito Google, chiavi pubblica e segreta

FASE 4

Netlify

Deploy, variabili ambiente, funzioni schedulare, build hook

FASE 5

Backup

Configurazione backup automatico, chiave admin, storage S3 opzionale

FASE 6

Go-Live

DNS, HTTPS, smoke test, checklist finale

1 Directus CMS — Hosting e configurazione

1.1 Requisiti hosting

Directus richiede un host con supporto Node.js 18+ oppure Docker. Le opzioni più comuni per progetti client:

- **cPanel con Node.js Selector** — soluzione economica, supportata dalla maggior parte dei provider condivisi (es. SiteGround, Aruba, Namecheap)
- **VPS con Docker** — maggior controllo, consigliato per progetti ad alto traffico
- **Railway / Render** — deploy in un click con immagine Docker ufficiale `directus/directus`

1.2 Database MySQL

- ☐ Crea un database MySQL 8+ dedicato al progetto

Da cPanel → Database Wizard, oppure da phpMyAdmin

- ☐ Crea un utente MySQL con tutti i permessi sul database

Segna: host, nome DB, utente, password — ti serviranno nella configurazione Directus

1.3 Installazione Directus

```
# Via npm (su VPS o cPanel con Node.js)
npm init directus-project@latest ./cms
# Seleziona: MySQL → inserisci credenziali DB
# Crea admin email + password

# Oppure via Docker
docker run -p 8055:8055 \
  -e DB_CLIENT=mysql \
  -e DB_HOST=db-host \
  -e DB_PORT=3306 \
  -e DB_DATABASE=nome_db \
  -e DB_USER=utente_db \
  -e DB_PASSWORD=password_db \
  -e SECRET=stringa_casuale_32_chars \
  directus/directus
```

1.4 Generare il token statico (DIRECTUS_TOKEN)

Il token statico è la chiave che il frontend usa per autenticarsi alle API Directus.

- ☐ Accedi al pannello admin Directus <https://cms.tuodominio.it/admin>
- ☐ Vai su **Settings** → **Users** → **Admin** (o crea un utente dedicato "API Bot" con ruolo Admin)
- ☐ Scorri fino a **Token** → clicca **Regenerate Token**
- ☐ Copia il token generato (visibile una sola volta) → incollalo in [DIRECTUS_TOKEN](#)

Attenzione: Usa un utente dedicato "API Bot" separato dall'admin personale. Se cambi la password dell'admin, il token rimane valido; se si disabilita l'utente, il token smette di funzionare.

1.5 Creare le collezioni con lo script

```
# Nella root del progetto, con .env configurato
node scripts/setup-collections.mjs
```

Crea automaticamente tutte le collezioni: [pages](#), [posts](#), [categories](#), [portfolio](#), [faq](#), [site_settings](#), [products](#), [product_categories](#), [product_variants](#), [shipping_zones](#), [orders](#), [order_items](#), [customers](#), [coupons](#), [gift_cards](#), [contact_submissions](#).

1.6 Configurare i permessi

- ☐ Settings → Roles → **Public**: permesso *read* su [pages](#), [posts](#), [categories](#), [portfolio](#), [faq](#), [site_settings](#), [products](#), [product_categories](#)
- ☐ Crea ruolo **Customer**: read su [orders](#) (filtro: [customer_email = \\$CURRENT_USER.email](#))
- ☐ Il ruolo **Admin** ha accesso completo (non modificare)

2 Stripe — Pagamenti e webhook

2.1 Creare account e ottenere le chiavi API

- ☐ Crea account su **dashboard.stripe.com** (o accedi se già esistente)
- ☐ Completa la verifica identità per attivare i pagamenti reali
- ☐ Vai su **Developers** → **API keys**
- ☐ Copia **Publishable key** (`pk_live_...`) → `STRIPE_PUBLISHABLE_KEY`
- ☐ Clicca **Reveal live key**, copia **Secret key** (`sk_live_...`) → `STRIPE_SECRET_KEY`

La secret key è visibile una sola volta. Salvala subito in un password manager.

Differenza test/live: In sviluppo usa le chiavi `pk_test_...` / `sk_test_...`. Le carte di test sono disponibili su docs.stripe.com/testing. Carta di test universale: `4242 4242 4242 4242`, qualsiasi scadenza futura, qualsiasi CVC.

2.2 Configurare il webhook

Il webhook notifica il backend quando un pagamento è completato.

- ☐ Vai su **Developers** → **Webhooks** → **Add endpoint**
- ☐ Endpoint URL: `https://tuodominio.it/api/webhook/stripe`
- ☐ Events: seleziona **checkout.session.completed**
- ☐ Clicca **Add endpoint** → vai su **Signing secret** → copia il valore `whsec_...` → `STRIPE_WEBHOOK_SECRET`

In sviluppo locale: usa Stripe CLI per forwardare gli eventi. Installa da stripe.com/docs/stripe-cli poi esegui:

```
stripe listen --forward-to localhost:4321/api/webhook/stripe
```

Il CLI stampa un webhook secret temporaneo (`whsec_...`) da usare in `.env` durante lo sviluppo.

3 Google reCAPTCHA v3

- ☐ Vai su **google.com/recaptcha/admin** → accedi con account Google
- ☐ Clicca **+** per registrare un nuovo sito
- ☐ Label: nome del progetto. Tipo: **Score based (v3)**
- ☐ Domains: inserisci `tuodominio.it` (senza https://). Aggiungi anche `localhost` per sviluppo
- ☐ Copia **Site Key** → `PUBLIC_RECAPTCHA_SITE_KEY`
Questa chiave è pubblica e va nel bundle JS del frontend
- ☐ Copia **Secret Key** → `RECAPTCHA_SECRET_KEY`
Questa chiave è privata, usata solo server-side per verificare il token

Score: reCAPTCHA v3 assegna uno score da 0.0 (bot) a 1.0 (umano). Il valore minimo accettato è configurabile con `RECAPTCHA_MIN_SCORE` (default: 0.5). Abbassa a 0.3 se ricevi falsi positivi da utenti legittimi.

4 Netlify — Deploy e configurazione

4.1 Creare il sito

- ☐ Netlify → **Add new site** → **Import an existing project**
- ☐ Connetti GitHub → seleziona la repo del cliente
- ☐ Build command: `npm run build`
- ☐ Publish directory: `dist`
- ☐ Node version: **22** (Site settings → Environment → Node version, oppure aggiungi `NODE_VERSION=22` nelle env vars)

4.2 Variabili d'ambiente su Netlify

Vai su **Site settings** → **Environment variables** e aggiungi tutte le variabili del `.env`:

Attenzione ai prefissi: Le variabili con prefisso `PUBLIC_` sono esposte nel browser (bundle JS). Tutte le altre sono accessibili solo server-side. Non mettere mai segreti in variabili `PUBLIC_`.

4.3 Build hook per Directus

- ☐ Netlify → Site settings → **Build hooks** → **Add build hook**
- ☐ Nome: "Directus Publish" → copia l'URL del hook
- ☐ In Directus → Settings → **Flows** → crea un flow con trigger "Action" su save/publish di `pages`, `posts`, `products`
- ☐ Aggiungi step "Webhook" → incolla l'URL Netlify (metodo POST)

4.4 ALLOWED_ORIGIN per le API

La variabile `ALLOWED_ORIGIN` protegge le API da richieste cross-origin non autorizzate. Deve corrispondere esattamente all'URL del sito (senza slash finale):

```
ALLOWED_ORIGIN=https://tuodominio.it # NO slash finale
```

Non usare `*` in produzione: esporrebbe il checkout e le API a chiamate da qualsiasi origine.

5 Backup automatico

5.1 Generare BACKUP_ADMIN_KEY

La chiave protegge l'endpoint `/api/admin/backup` da accessi non autorizzati. Deve essere una stringa casuale sicura:

```
# Genera una chiave sicura con Node.js
node -e "console.log(require('crypto').randomBytes(32).toString('hex'))"

# Oppure con openssl
openssl rand -hex 32
```

Copia l'output → `BACKUP_ADMIN_KEY`. Usa la stessa chiave su Netlify e nel file `.env` locale.

5.2 Schedule automatico

La Netlify Scheduled Function si attiva in base al valore di `BACKUP_CRON`:

```
BACKUP_CRON=@daily      # ogni giorno a mezzanotte UTC (default)
BACKUP_CRON=0 2 * * *   # ogni giorno alle 02:00 UTC
BACKUP_CRON=@weekly     # ogni domenica
```

5.3 Storage S3 (opzionale)

Per archiviare i backup su cloud (AWS S3, Backblaze B2, Cloudflare R2, MinIO):

- ☐ Crea un bucket S3 dedicato al progetto
- ☐ Crea un utente IAM con permesso `s3:PutObject` sul solo bucket
- ☐ Genera Access Key + Secret Key per l'utente IAM
- ☐ Imposta `BACKUP_STORAGE=s3` e compila tutte le variabili `BACKUP_S3_*`

6 Go-Live — DNS e checklist finale

6.1 Dominio su Netlify

- ☐ Netlify → Domain management → **Add custom domain**
- ☐ Sul provider DNS crea record: **CNAME** `www` → `nome-sito.netlify.app`
- ☐ Per il dominio apex (`@`): usa i Netlify DNS (nameserver) oppure un record **A** → `75.2.60.5`
- ☐ Abilita **HTTPS** (automatico con Let's Encrypt dopo propagazione DNS)
- ☐ Attendi propagazione DNS: da 15 minuti a 48 ore (media: 1-2 ore)

6.2 Smoke test

- ☐ Homepage, blog, portfolio si caricano correttamente
- ☐ Negozio: lista prodotti, categoria, scheda prodotto
- ☐ Aggiungi prodotto al carrello → badge aggiornato
- ☐ Checkout con carta test Stripe (4242 4242 4242 4242)
- ☐ Pagina success: ordine creato, link download per prodotti digitali
- ☐ Webhook Stripe: verifica in Stripe Dashboard → Webhooks → last events
- ☐ Form contatti: invio → verifica su Directus + eventuale email
- ☐ Area account: login, lista ordini, dettaglio ordine
- ☐ Backup manuale: `npm run backup -- --dry-run` → verifica output
- ☐ Build hook: pubblica un contenuto su Directus → verifica deploy automatico su Netlify

7 Variabili d'ambiente — Riferimento completo

Copia `.env.example` in `.env` e compila ogni variabile seguendo questa guida. Le variabili marcate **RICHIESTA** bloccano il funzionamento del sito se mancanti.

DIRECTUS CMS

VARIABILE	DESCRIZIONE E DOVE TROVARLA
<code>DIRECTUS_URL</code> RICHIESTA	URL base dell'istanza Directus, senza slash finale. Es: <code>https://cms.tuodominio.it</code> → URL del tuo hosting Directus
<code>DIRECTUS_TOKEN</code> RICHIESTA	Token statico per autenticarsi alle API Directus. → Directus Admin → Settings → Users → [utente API] → Token → Regenerate

STRIPE — PAGAMENTI

VARIABILE	DESCRIZIONE E DOVE TROVARLA
<code>STRIPE_SECRET_KEY</code> RICHIESTA	Chiave segreta Stripe. Formato: <code>sk_live_...</code> (prod) / <code>sk_test_...</code> (dev). → dashboard.stripe.com → Developers → API keys → Secret key
<code>STRIPE_PUBLISHABLE_KEY</code> RICHIESTA	Chiave pubblica Stripe. Formato: <code>pk_live_...</code> / <code>pk_test_...</code> . Visibile nel bundle JS. → dashboard.stripe.com → Developers → API keys → Publishable key
<code>STRIPE_WEBHOOK_SECRET</code> RICHIESTA	Segreto per verificare la firma degli eventi webhook. Formato: <code>whsec_...</code> . → dashboard.stripe.com → Developers → Webhooks → [endpoint] → Signing secret In sviluppo: <code>stripe listen --forward-to localhost:4321/api/webhook/stripe</code> → il CLI stampa il segreto temporaneo

APPLICAZIONE

VARIABILE		DESCRIZIONE E DOVE TROVARLA
<code>PUBLIC_SITE_URL</code>	RICHIESTA	URL pubblico del sito, senza slash finale. Usato per costruire link assoluti (es. redirect Stripe success/cancel). Es: <code>https://tuodominio.it</code> → Il dominio del cliente su Netlify
<code>ALLOWED_ORIGIN</code>	RICHIESTA	Origine autorizzata per le chiamate alle API (CORS). Deve corrispondere esattamente a <code>PUBLIC_SITE_URL</code> . Es: <code>https://tuodominio.it</code> → Stesso valore di PUBLIC_SITE_URL. Non usare * in produzione.
<code>DEFAULT_LOCALE</code>	OPZIONALE	Lingua di default del sito. Valori: <code>it</code> (default) oppure <code>en</code> . → Imposta manualmente in base alla lingua del sito cliente

EMAIL SMTP (OPZIONALE — SOLO SE VUOI INVIARE NOTIFICHE)

VARIABILE		DESCRIZIONE E DOVE TROVARLA
<code>SMTP_HOST</code>	OPZIONALE	Host del server SMTP. Se vuoto, l'invio email è disabilitato (il form contatti salva solo su Directus). Es: <code>smtp.gmail.com</code> , <code>smtp.sendgrid.net</code> , <code>mail.tuodominio.it</code> → Dal pannello del provider email (cPanel → Email → Impostazioni client)
<code>SMTP_PORT</code>	OPZIONALE	Porta SMTP. Valori comuni: <code>587</code> (STARTTLS, default), <code>465</code> (SSL), <code>25</code> (non sicuro). → Dal pannello provider email
<code>SMTP_USER</code>	OPZIONALE	Username SMTP, solitamente l'indirizzo email mittente. Es: <code>noreply@tuodominio.it</code> → Dal pannello provider email / cPanel → Email Accounts
<code>SMTP_PASS</code>	OPZIONALE	Password SMTP. Per Gmail usa una <i>App Password</i> (non la password account Google). → Per Gmail: myaccount.google.com → Security → 2-Step Verification → App passwords
<code>CONTACT_EMAIL_TO</code>	OPZIONALE	Indirizzo email destinatario delle notifiche del form contatti. Es: <code>info@tuodominio.it</code> → Inserisci manualmente l'email del cliente

GOOGLE RECAPTCHA V3

VARIABILE	DESCRIZIONE E DOVE TROVARLA
PUBLIC_RECAPTCHA_SITE_KEY OPZIONALE	Chiave pubblica reCAPTCHA v3. Viene inclusa nel bundle JS del frontend. Se vuota, il form contatti funziona senza protezione bot. → google.com/recaptcha/admin → <i>seleziona sito</i> → <i>Site Key</i>
RECAPTCHA_SECRET_KEY OPZIONALE	Chiave segreta usata server-side per verificare il token reCAPTCHA. → google.com/recaptcha/admin → <i>seleziona sito</i> → <i>Secret Key</i>
RECAPTCHA_MIN_SCORE OPZIONALE	Score minimo accettato (0.0 = bot, 1.0 = umano). Default: 0.5. Abbassa a 0.3 se ricevi troppi falsi positivi. → <i>Imposta manualmente in base alle esigenze del cliente</i>

BACKUP AUTOMATICO

VARIABILE		DESCRIZIONE E DOVE TROVARLA
BACKUP_ADMIN_KEY	RICHIESTA	Chiave segreta per proteggere l'endpoint <code>/api/admin/backup</code>. Genera con: <code>node -e "console.log(require('crypto').randomBytes(32).toString('hex'))"</code> → <i>Genera localmente, copia su Netlify nelle env vars</i>
BACKUP_STORAGE	OPZIONALE	Tipo di storage per i backup. Valori: <code>local</code> (default) oppure <code>s3</code>. → <i>Imposta manualmente. Usa <code>s3</code> per backup remoti su AWS/Backblaze/R2</i>
BACKUP_LOCAL_PATH	OPZIONALE	Percorso locale dove salvare i backup. Default: <code>./backups</code>. → <i>Imposta solo se vuoi un percorso personalizzato</i>
BACKUP_CRON	OPZIONALE	Schedule per il backup automatico (Netlify Scheduled Function). Default: <code>@daily</code>. Esempi: <code>@daily</code>, <code>@weekly</code>, <code>0 2 * * *</code> (ogni notte alle 2 UTC). → <i>Imposta su Netlify nelle env vars</i>
BACKUP_S3_ENDPOINT	OPZIONALE	Endpoint S3-compatible. Solo se <code>BACKUP_STORAGE=s3</code>. Es: <code>https://s3.eu-central-1.amazonaws.com</code>, <code>https://s3.eu-central-003.backblazeb2.com</code> → <i>Dal pannello del provider S3 (AWS, Backblaze B2, Cloudflare R2, MinIO)</i>
BACKUP_S3_BUCKET	OPZIONALE	Nome del bucket S3. → <i>AWS S3 → Buckets → nome del bucket creato</i>
BACKUP_S3_REGION	OPZIONALE	Regione AWS del bucket. Default: <code>eu-central-1</code>. Es: <code>us-east-1</code>, <code>eu-west-1</code> → <i>Visible nella console AWS durante creazione bucket</i>
BACKUP_S3_ACCESS_KEY	OPZIONALE	Access Key ID dell'utente IAM dedicato ai backup. → <i>AWS Console → IAM → Users → [utente backup] → Security credentials → Create access key</i>
BACKUP_S3_SECRET_KEY	OPZIONALE	Secret Access Key IAM. Visibile solo al momento della creazione. → <i>AWS IAM → create access key → copia e salva subito (non è recuperabile)</i>
BACKUP_S3_PREFIX	OPZIONALE	Prefisso (cartella virtuale) dentro il bucket. Default: <code>backups/</code>. Utile per organizzare più progetti nello stesso bucket: <code>cliente-x/backups/</code> → <i>Imposta manualmente</i>

8 File .env completo — Template di riferimento

```
# — Directus —
DIRECTUS_URL=https://cms.tuodominio.it
DIRECTUS_TOKEN=il_token_generato_da_directus

# — Stripe —
STRIPE_SECRET_KEY=sk_live_xxxxx
STRIPE_PUBLISHABLE_KEY=pk_live_xxxxx
STRIPE_WEBHOOK_SECRET=whsec_xxxxx

# — App —
PUBLIC_SITE_URL=https://tuodominio.it
ALLOWED_ORIGIN=https://tuodominio.it
DEFAULT_LOCALE=it

# — Email SMTP (opzionale) —
SMTP_HOST=smtp.tuodominio.it
SMTP_PORT=587
SMTP_USER=noreply@tuodominio.it
SMTP_PASS=password_smtp
CONTACT_EMAIL_TO=info@tuodominio.it

# — reCAPTCHA v3 (opzionale) —
PUBLIC_RECAPTCHA_SITE_KEY=6LcXXXXXXXXXXXXXXXXX
RECAPTCHA_SECRET_KEY=6LcXXXXXXXXXXXXXXXXX
RECAPTCHA_MIN_SCORE=0.5

# — Backup —
BACKUP_ADMIN_KEY=chiave_generata_con_crypto_randomBytes_32
BACKUP_STORAGE=local # oppure: s3
BACKUP_LOCAL_PATH=./backups
BACKUP_CRON=@daily

# — Backup S3 (solo se BACKUP_STORAGE=s3) —
BACKUP_S3_ENDPOINT=https://s3.eu-central-1.amazonaws.com
BACKUP_S3_BUCKET=nome-bucket
BACKUP_S3_REGION=eu-central-1
BACKUP_S3_ACCESS_KEY=AKIAIOSFODNN7EXAMPLE
BACKUP_S3_SECRET_KEY=wJalrXUtnFEMI/K7MDENG/bPxRfiCYEXAMPLEKEY
BACKUP_S3_PREFIX=backups/
```

Checklist variabili minime per il primo deploy:

DIRECTUS_URL · DIRECTUS_TOKEN · STRIPE_SECRET_KEY · STRIPE_PUBLISHABLE_KEY ·
STRIPE_WEBHOOK_SECRET · PUBLIC_SITE_URL · ALLOWED_ORIGIN · BACKUP_ADMIN_KEY